

AUDITORÍAS DE SEGURIDAD: PLANIFICACIÓN

El plano de operaciones para un
pentesting efectivo.

Presentado por Carlos Noboa

El Qué: Alcance y Enfoque

Definir los sistemas objetivo, el tipo de revisión y las exclusiones.

El Quién: Logística y Accesos

Identificar contactos clave, roles, credenciales y protocolos de escalado.

El Cómo: Metodología

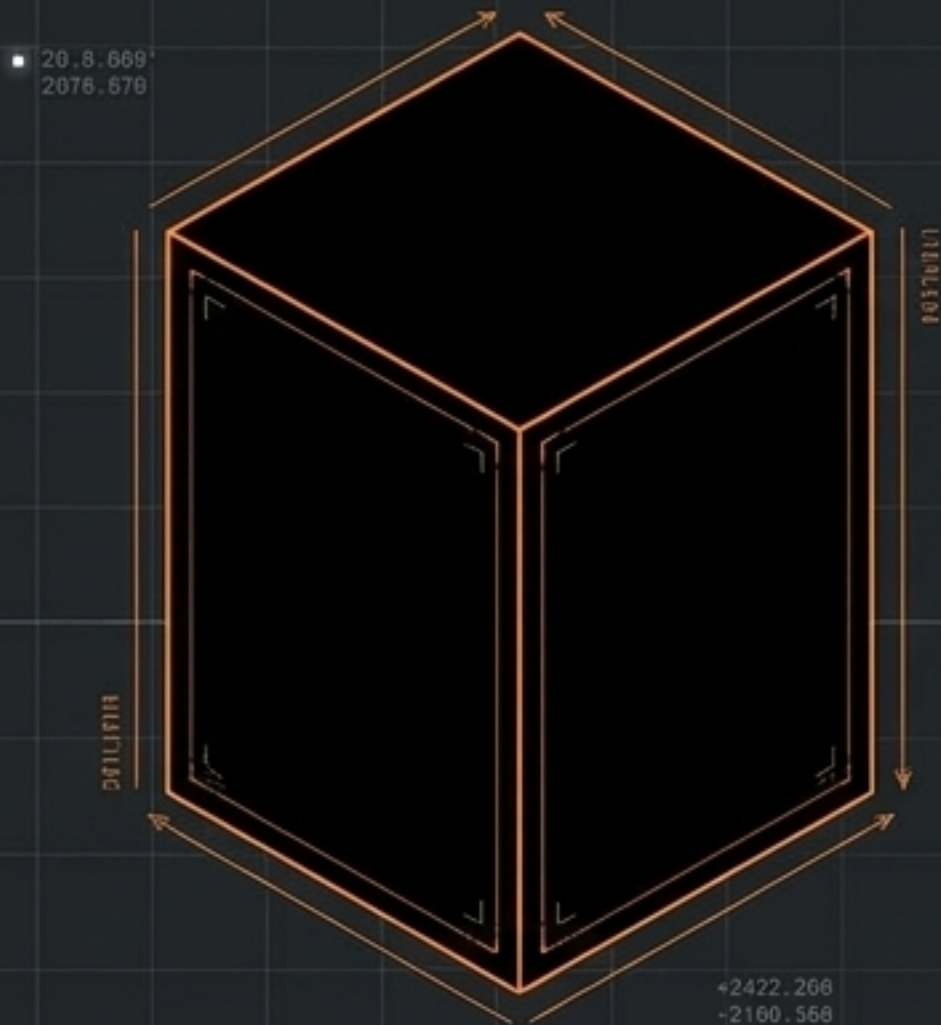
Acordar técnicas, automatización vs. manual, y pruebas permitidas.

Fase 0: Planificación

El Cuándo y Dónde: Entorno y Tiempos

Seleccionar el terreno de pruebas (Pre/Pro) y las ventanas horarias de ejecución.

El Punto de Partida: Nivel de Conocimiento Previo



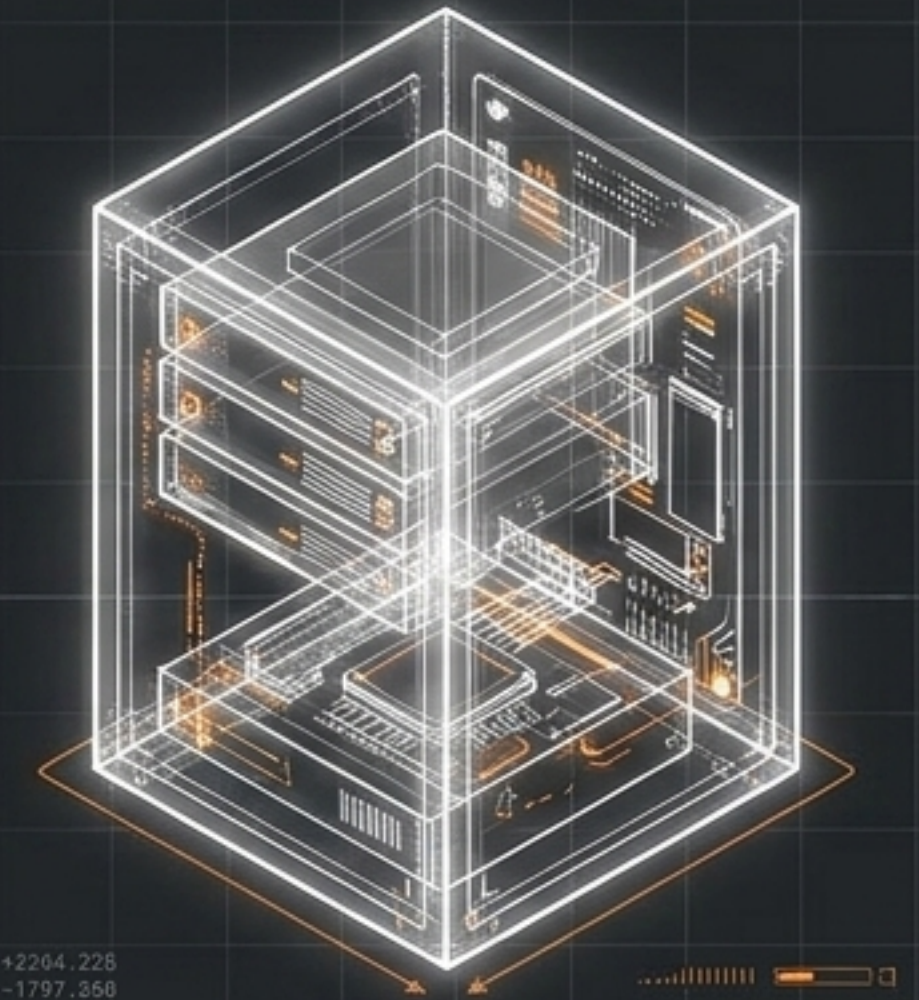
Caja Negra

Emula a un atacante real externo. El pentester opera sin ningún conocimiento previo de la infraestructura o sistemas a auditar.



Caja Gris

Un enfoque híbrido. El auditor dispone de conocimiento parcial; por ejemplo, acceso como usuario sin privilegios y cierto detalle sobre las funcionalidades.



Caja Blanca

Transparencia total. La auditoría se ejecuta con conocimiento completo de la infraestructura, usuarios e incluso acceso al código fuente.

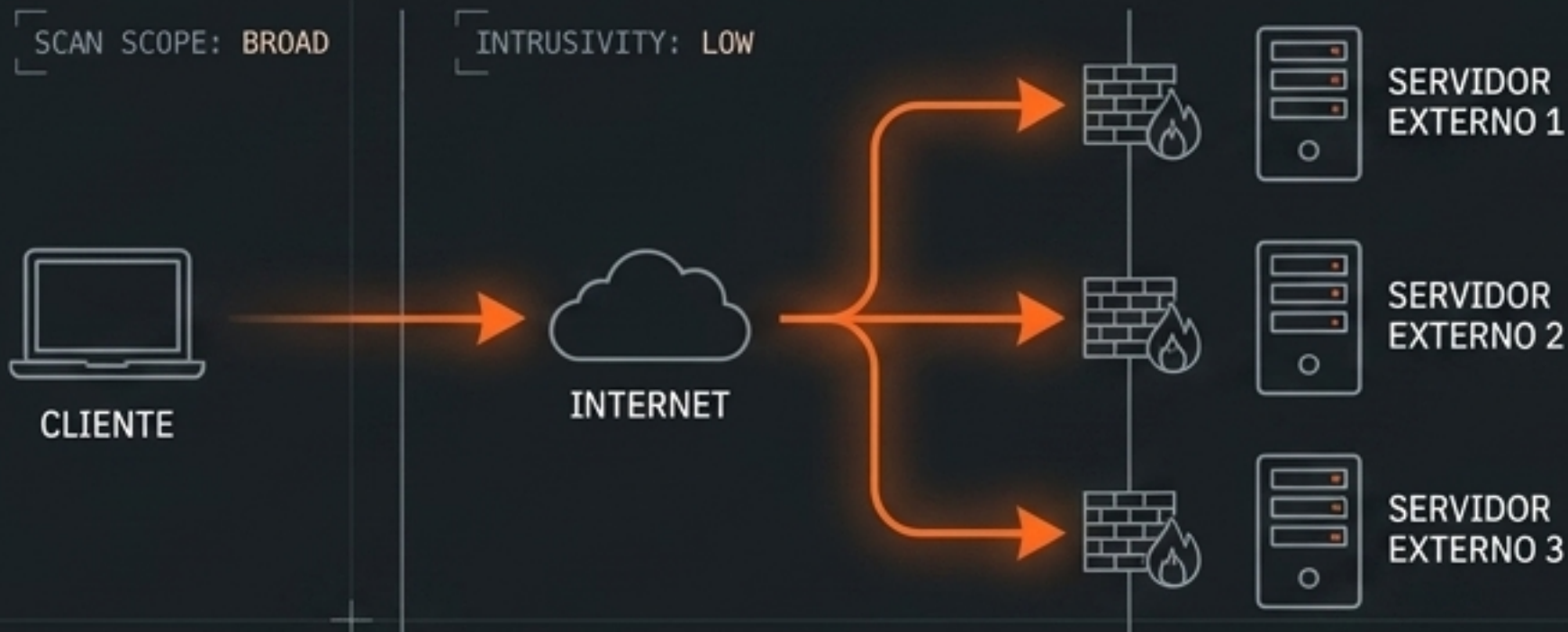
Definición del Alcance: Amplitud vs. Profundidad

Alcance Horizontal

Revisión de todos los activos visibles desde una red determinada (ej. Internet).

Poco intrusivo.

Normalmente no contempla la explotación profunda de las vulnerabilidades detectadas.

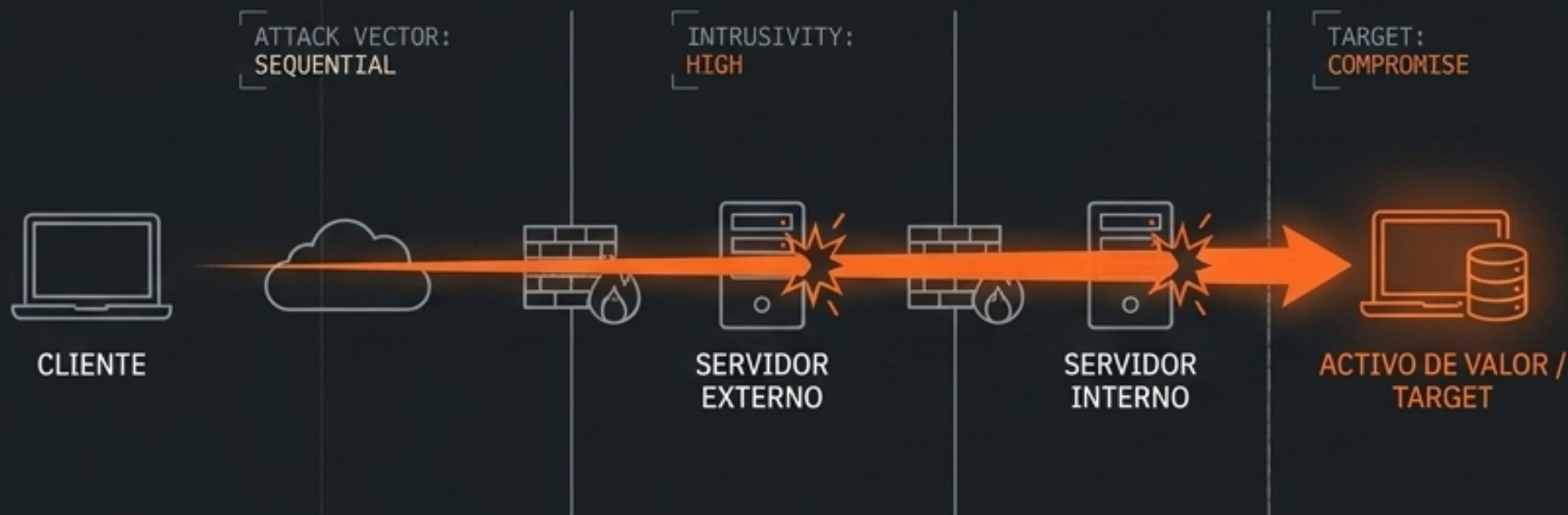


Alcance Vertical

El objetivo es comprometer el activo de mayor valor con el máximo privilegio posible.

Altamente intrusivo.

Exige explotar todas las vulnerabilidades en cadena para atravesar las defensas.



Metodología y Herramientas (Rules of Engagement)

SCAN MATRIX

STATUS: **READY**

Automática

HIGH



Velocidad

LOW



Precisión (Falsos Positivos)

LOW



Control

LOW



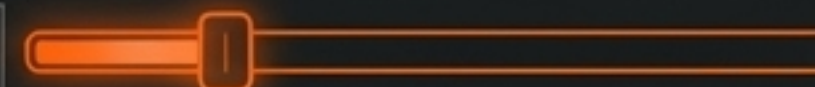
Detección de Lógica de Negocio

Eficiencia temporal alta, amplio abanico inicial. Excelente en entornos estándares.
Contras: Pérdida de control, genera falsos positivos, incapacidad para detectar fallos en la lógica de negocio.

(Herramientas: Nessus, Nmap, Acunetix)

Manual

LOW



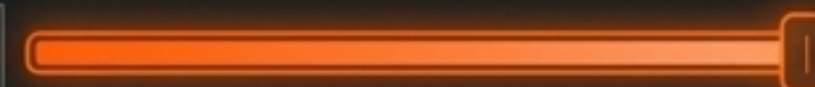
Velocidad

HIGH



Precisión (Falsos Positivos)

HIGH



Control

HIGH



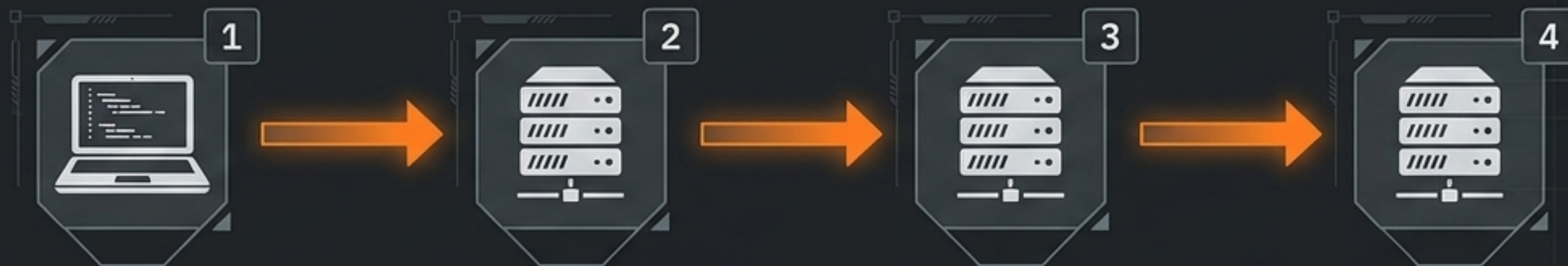
Detección de Lógica de Negocio

Exhaustividad y alto control de las pruebas. Eficaz en cualquier entorno, detecta fallos lógicos complejos.
Contras: Requiere mucho más tiempo y enfoque reducido inicial.

(Herramientas: Burpsuite, scripts a medida)

Acuerdos Críticos: Definir explícitamente qué pruebas están permitidas, cuáles están totalmente prohibidas y consideraciones operativas específicas.

El Terreno de Juego: Riesgo Operativo vs. Realismo



Desarrollo

Espacio local del programador. Pruebas iniciales de código.
Riesgo Nulo / Realismo Bajo.

Integración

Unificación de código.
Aún presenta grandes diferencias con los entornos productivos.

Preproducción

Emula el entorno final para testear cambios. Misma configuración técnica que producción, pero con datos anonimizados.
(Sweet spot recomendado).

Producción

Usuarios y datos de negocio reales. Controles defensivos activos (WAF/Firewalls).
Implicaciones legales/económicas.
Riesgo Crítico (caída de servicio) / Realismo Máximo.

Nivel de Riesgo Operativo

Realismo de la Prueba



Logística de Ejecución: Tiempos y Protocolos de Contacto

Fechas y Franjas Horarias



- Fecha de inicio y finalización del engagement.
- Ventanas de ejecución permitidas (¿Se realizarán pruebas de alto impacto en horario de oficina o oficina o de madrugada para mitigar riesgos operacionales?).

Matriz de Escalado

Contact Card



Contacto Técnico

El interlocutor directo para resolver dudas arquitectónicas o funcionales de la aplicación durante el pentest.

CONTACT_PRIORITY: P1

STATUS: AVAILABLE

Contact Card



Contacto de Emergencia

La autoridad con quien contactar inmediatamente en caso de una incidencia crítica (ej. denegación de servicio accidental).

CONTACT_PRIORITY: P1

STATUS: AVAILABLE

Despliegue Operativo: Requisitos de Acceso

Pre-flight Checklist



Usuarios y Credenciales

Provisión de cuentas de prueba válidas (si aplica al enfoque).



Asignación de Roles

Mapeo exacto de los niveles de privilegio otorgados al auditor frente a los perfiles de usuario reales.



Documentación Adicional

Entrega de descripciones de funcionalidades, mapeo de APIs, o excepciones operativas críticas.

[SISTEMA LISTO - FIN DE LA FASE DE PLANIFICACIÓN]